

Which frameworks put your Wi-Fi in scope

When the network carries card data, ePHI, a public company's financial systems, or EU personal data, the design inherits requirements. Recognize you are in scope, know what the framework generally wants, then route the specifics to the owner.

FRAMEWORK	YOU ARE IN SCOPE WHEN...	WHAT IT GENERALLY ASKS OF THE NETWORK	WHO OWNS IT (ROUTE TO)
PCI DSS v4.0.1 · future-dated reqs live	The Wi-Fi transmits or connects to systems that store or process cardholder data - retail, hospitality, any card-present site.	• Segment APs from the Cardholder Data Environment; guest on a separate VLAN, internet-only, firewalled (VLANs alone are not segmentation) • WPA2-AES / WPA3 minimum, no weak fallback - WEP and WPA/TKIP prohibited; PCI steers the CDE to 802.1X/EAP, PSK discouraged • No default credentials on wireless gear • Quarterly rogue-AP scanning (Req 11.2.1) - required even with no Wi-Fi deployed • Logging and audit trails	↔ QSA Qualified Security Assessor or internal PCI lead owns scoping and validation.
HIPAA Security Rule §164.312	The network carries or connects to systems holding ePHI - covered entities and their business associates.	• Access control - unique user IDs, automatic logoff • Audit controls - record access to and activity in ePHI systems • Integrity - protect ePHI from improper alteration • Transmission security - strong encryption (WPA2/WPA3-Enterprise, TLS 1.2+ in transit) • Note: encryption is currently addressable; a Jan 2025 NPRM proposes making it mandatory	↔ Privacy / security officer Health system's privacy / security officer; biomed for the device RF side.
SOX / SEC Section 404 · via ITGCs	The client is a US public company . SOX reaches the network through IT General Controls over financial-reporting systems.	• Access controls - who can reach financial systems and their segments; least privilege; provisioning / de-provisioning • Change management - network changes follow documented, approved, auditable processes (not ad-hoc console changes) • Audit trails - evidence controls operate, retained for the auditor	↔ Internal audit Internal audit / IT compliance plus the external auditor. Narrowest network fit.
GDPR network overlay	The network processes EU personal data - captive-portal logins, MAC / identity logging, RTLS of identifiable people.	• Data minimization - do not log more than needed • Storage limitation - retention windows on Wi-Fi logs • Security of processing - encryption and access control • Residency / sovereignty of wherever those logs land, including any cloud Wi-Fi platform holding them	↔ Privacy officer / DPO Loops straight back to vetting the cloud tool that holds the logs.